

Privacy-Preserving UPI Tiering: A Multi-Predicate Zero-Knowledge-Proof eKYC Framework for India's Payment Infrastructure

Abstract—India's Unified Payments Interface (UPI) gates transaction limits behind Know Your Customer (KYC) compliance tiers mandated by the Reserve Bank of India (RBI) and National Payments Corporation of India (NPCI). Unlocking the Full KYC tier currently requires users to surrender sensitive identity documents (Aadhaar, PAN, income proofs) to Payment Service Providers (PSPs). This centralized storage creates severe breach vulnerabilities and systemically violates the data minimization principle of India's Digital Personal Data Protection (DPDP) Act 2023, Section 8(3).

We present ZKProof-eKYC, the first Zero-Knowledge Proof (ZKP) framework designed specifically for *payment system tier access control*. By reframing KYC eligibility as a cryptographic access token, a user's device generates a 1.5 KB non-interactive Groth16 zk-SNARK proof asserting tier eligibility. The PSP receives only a boolean result, eliminating personal data transmission and achieving DPDP Act compliance mathematically.

The primary contribution is a multi-predicate Circom 2.0 circuit ($\approx 25,000$ R1CS constraints) simultaneously enforcing eleven regulatory predicates (ϕ_{age} to ϕ_{tier}) mapped across six Indian statutes. The architecture introduces five key elements: (i) an 8-leaf depth-3 Poseidon Merkle credential tree; (ii) a dual-document commitment scheme protecting the raw PAN (single-hash) and Aadhaar (double-hash) identifiers; (iii) an EdDSA-Poseidon issuer signature; (iv) a depth-20 Sparse Merkle Tree (SMT) for real-time revocation; and (v) Poseidon nonce-binding against replay attacks.

A novel branch-free finite-field formula calculates NPCI's tier limits natively: $\text{tier} = 2 \cdot \mathbb{K}[\text{FullKYC}] + (1 - \mathbb{K}[\text{FullKYC}]) \cdot \mathbb{K}[\text{MinKYC}]$. We deploy a dual-circuit framework: `UPIKYCTierProof` for Full KYC and `MinKYCTierProof` for Min KYC. Functional correctness is validated against 12 adversarial test vectors. Performance profiling projects mobile WASM generation at <400 ms, with off-chain execution measured at ≈ 96 ms and on-chain verification at $\approx 242,000$ gas. ZKProof-eKYC establishes the first “one credential, multiple products” ZKP architecture for national payment infrastructure.

Index Terms—Zero-Knowledge Proofs, eKYC, UPI, Groth16, zk-SNARK, Circom, Poseidon, Sparse Merkle Tree, Privacy-Preserving Identity, DPDP Act

I. INTRODUCTION

A. India's UPI Ecosystem and the KYC Access Problem

India's Unified Payments Interface (UPI) processes over 14 billion monthly transactions across more than 300 million active users [1]. Access is governed by a tiered KYC compliance system mandated by NPCI and RBI [2]: *No KYC* permits no transactions; *Min KYC* permits up to Rs. 10,000 per transaction and Rs. 1,00,000 monthly, with no P2P transfers; *Full KYC* raises this to Rs. 1,00,000 per transaction with unlimited monthly volume and P2P access. Higher merchant and capital-markets tiers extend limits further but are not the focus of this work. Unlocking Full KYC is therefore the effective gateway to India's digital financial ecosystem, permitting peer-to-peer transfers, high-value transactions, and large UPI AutoPay mandates.

To achieve Full KYC, users currently surrender highly sensitive identity documents - including Aadhaar numbers,

Permanent Account Number (PAN) cards, and income proofs - to Payment Service Providers (PSPs) for centralised storage. This architecture suffers from three structural failures:

- **Breach Risk:** Centralised repositories are high-value targets, exemplified by the 2021 MobiKwik breach of 3.5 million users [3]. This exposes PSPs to massive liabilities under the IT Act 2000, Section 43A [4].
- **Data Minimisation Violation:** KYC verification only requires a boolean answer (“Does this user qualify?”). Collecting entire dossiers structurally violates the data minimisation mandate of the DPDP Act 2023, Section 8(3) [5].
- **Lack of User Sovereignty:** Users cannot retract submitted data, which is retained indefinitely under PMLA Rules [6], often violating the strict sharing limitations of the Aadhaar Act 2016 [7].

B. The ZKP Literature Gap

While Zero-Knowledge Proofs (ZKPs) [8] are ideally suited for boolean eligibility claims, existing ZKP eKYC literature [9]–[12] remains confined to generic identity authentication. Even the most technically similar selective disclosure systems evaluate at most three basic attributes [9]. A critical gap exists: no prior work has extended ZKPs to *payment system tier access control*, nor mapped constraints to a complex national regulatory stack involving transaction limits, Politically Exposed Person (PEP) checks, and document redaction.

C. ZKProof-eKYC: Conceptual Reframing

ZKProof-eKYC reframes KYC tier eligibility: *it is not data to be disclosed, but a property to be proved*.

Instead of transmitting documents, the user's device generates a succinct 1.5 KB Groth16 zk-SNARK asserting Full KYC eligibility. The PSP verifies this proof in ≈ 96 ms, receiving only a boolean result. This architectural shift enforces compliance with the DPDP Act, IT Act, PMLA, and Aadhaar Act via cryptography rather than policy, as no personal data is ever transmitted, processed, or stored at the PSP layer.

D. Contributions

This paper presents the first ZKP framework for payment access control, making the following verifiable contributions:

- 1) **Multi-Predicate Circuit:** The first Groth16 circuit encoding eleven simultaneous regulatory predicates (ϕ_{age} through ϕ_{tier}) for Full KYC eligibility.
- 2) **Regulatory Mapping:** A formal mathematical mapping of circuit constraints to six Indian financial and privacy statutes.
- 3) **Dual-Document Commitment:** A nested hash scheme satisfying Aadhaar and RBI regulations without raw identifiers entering the circuit.

- 4) **Branch-Free Tier Arithmetic:** A finite-field formula natively calculating NPCI's three-tier limits within the BN128 scalar field.
- 5) **Integrated SMT Revocation:** Real-time credential revocation via a depth-20 Sparse Merkle Tree (SMT) and unlinkable session nullifiers.
- 6) **Extensible Dual-Circuit Framework:** A scalable architecture (UPIKYCTierProof and MinKYCTierProof) natively extensible to broader NPCI products (NACH, FASTag, RuPay).

II. RELATED WORK

The application of Zero-Knowledge Proofs to identity verification has accelerated rapidly, driven by the inherent conflict between stringent Know Your Customer (KYC) regulations and emerging data privacy frameworks. However, a critical review of the literature reveals that existing work is confined entirely to generic identity authentication, leaving the domain of payment system access control completely unaddressed.

A. Zero-Knowledge eKYC and Selective Disclosure

The baseline for ZKP-based selective disclosure in eKYC is established by Ahmed et al. [9], who implement a Poseidon Merkle tree evaluated inside a Groth16 zk-SNARK. Their system allows a prover to demonstrate membership of three generic attributes (date of birth, name, and university) without revealing the attributes themselves. While architecturally sound, achieving 312 ms proof generation times, their circuit is limited to single-tier, stateless identity claims. It lacks an on-chain revocation mechanism, does not map to any statutory financial framework, and evaluates a maximum of three simple predicates.

Similarly, Srinivas et al. [12] propose ZKPass, an authentication system utilising Circom and Groth16. However, ZKPass operates primarily on a single Unique Identifier (UID) rather than a multi-attribute credential tree, restricting its utility in financial sectors where regulatory compliance demands simultaneous verification of age, income, and specific document types. Kumar et al. [11] expand the technical tooling by leveraging the Ethereum Attestation Service (EAS) and the SP1 zkVM for zero-knowledge identity verification. While their use of general-purpose zkVMs offers structural flexibility, their general-purpose zkVM-based approach does not explicitly target the sub-second mobile on-device proving loops necessary for real-time retail merchant transaction flows.

B. Blockchain Identity and Reputation Systems

A parallel vector of research explores blockchain-based identity. However, non-ZKP blockchain eKYC systems [13]–[15] still transmit or decrypt plaintext identity data at the verifier boundary, fundamentally failing the data minimisation mandate of the DPDP Act 2023 [5] by construction. While Kalbantner et al. [10] apply ZKPs via Soulbound Tokens (SBTs), their framework targets discrete P2P marketplace reputation and binary access rather than the high-frequency, tiered transaction limit infrastructure required for payment systems.

C. The Indian Context and the Payment Tier Gap

Within the Indian regulatory context, Vijayakumaran [16] demonstrates privacy-preserving Aadhaar-based age proofs. However, this is a single-predicate construction focused strictly on proving age ≥ 18 . A complete Full KYC verification for UPI requires satisfying RBI Master Directions Para 13 and Para 27 simultaneously - which mandates verifying age, income class, residence status, PAN linkage, and Aadhaar linkage, whilst also screening for Politically Exposed Persons (PEPs) [6], [17].

Comprehensive surveys of ZKP frameworks by Lavin [18] and Sheybani [19] confirm this literature gap: no published ZKP system has successfully modelled payment tier access control. Current systems answer the question, “Is this identity authentic?” None answer the multi-dimensional regulatory question, “What is the maximum statutory transaction limit for this identity?” ZKProof-eKYC bridges this definitive gap by introducing a dual-document commitment scheme and branch-free tier arithmetic, scaling circuit complexity to eleven simultaneous statutory predicates to execute multi-tier payment logic in zero-knowledge.

III. PROBLEM STATEMENT AND TRUST MODEL

A. Formal Problem Statement

Let U be a UPI user possessing a private KYC credential comprising eight distinct identity attributes. We define the user's private witness vector w as:

$$w = \{w_{\text{dob}}, w_{\text{inc}}, w_{\text{doc}}, w_{\text{pan}}, w_{\text{aadhaar}}, w_{\text{res}}, w_{\text{iss}}, w_{\text{id}}\}$$

Under the DPDP Act 2023, the raw elements of w must never be transmitted in plaintext to the verifier.

Let $T : w \rightarrow \{0, 1, 2\}$ be the KYC tier classification function defined by NPCI regulations, mapping to No KYC (0), Minimum KYC (1), and Full KYC (2). Let $\mathcal{T}^*$ be the required threshold tier for a given payment request (e.g., $\mathcal{T}^* = 2$ for a Rs. 1,00,000 P2P transfer).

Problem: Construct a Zero-Knowledge Proof system (P, V) leveraging Groth16 over the alt_bn128 curve, such that a prover P can generate a succinct, non-interactive proof π satisfying:

$$\pi \leftarrow \text{Prove}(\mathbf{pk}, x, w) \quad (1)$$

$$b \leftarrow \text{Verify}(\mathbf{vk}, x, \pi) \in \{\text{accept}, \text{reject}\} \quad (2)$$

The public input vector x exposes only cryptographic state and payment parameters:

$$x = \{\text{issuerPubKey}, \text{merkleRoot}, \text{revRoot}, \text{nonce}, \text{boundHash}, \text{currYear}, \text{txAmount}, \text{tierLimit}\}$$

The system must mathematically guarantee:

- 1) **Completeness:** If $T(w) \geq \mathcal{T}^*$ and the credential is unrevoked, an honest P running the WASM circuit locally can always generate a valid π that V accepts with probability 1.

- 2) **Soundness:** If $T(w) < \mathcal{T}^*$, no computationally bounded adversarial prover $\mathcal{A}$ can generate an accepting π except with negligible probability $\text{negl}(\lambda)$.
- 3) **Zero-Knowledge:** The verifier's view is computationally indistinguishable from a simulator $\mathcal{S}$ possessing no knowledge of w :

$$\text{View}_V(P(w) \leftrightarrow V)(x) \stackrel{c}{\approx} \mathcal{S}(x)$$

B. Cryptographic Trust Model

The traditional prover-verifier dichotomy is insufficient for a production-grade Indian financial deployment. To achieve DPDP Act compliance without degrading the UPI user experience (UX), we separate our analysis into a core cryptographic trust model across three distinct boundaries.

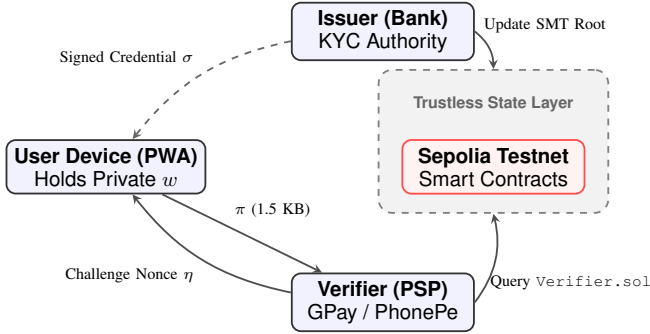


Fig. 1. Cryptographic Trust Boundaries in ZKProof-eKYC.

- **Regulated Issuer ($\mathcal{I}$):** An RBI-licensed entity trusted to honestly perform KYC, build the Merkle tree, sign the root via EdDSA on the Baby Jubjub curve, and report SMT revocations.
- **Prover Application ($\mathcal{P}$):** A Progressive Web App (PWA) executing the WASM-compiled Circom prover and securing w in IndexedDB via WebAuthn (AES-256-GCM). It relies strictly on cryptography, assuming an uncompromised host OS.
- **Verifier / PSP ($\mathcal{V}$):** The payment aggregator providing the challenge nonce η via QR code, modeled as fully untrusted with personal data.

C. Credential Merkle Tree and Double-Commitments

To enable granular selective disclosure, the credential is mathematically structured as a depth-3 Poseidon Merkle tree containing 8 leaves. Table I maps each leaf to its specific statutory mandate.

The Dual-Document Double-Commitment: A critical compliance challenge arises from Aadhaar Act Section 29 (prohibiting raw identifier sharing) and RBI Para 13(c) (mandating PAN linkage). If raw document strings enter the Circom circuit, they risk exposure via memory side-channels or malicious circuit forks.

TABLE I
CREDENTIAL MERKLE TREE STRUCTURE & REGULATORY MAPPING

Idx	Attribute Hash Formulation	Statutory Basis
L_0	$\text{Poseidon}(\text{birthYear}, s_0)$	RBI Para 13(a)
L_1	$\text{Poseidon}(\text{incClass}, s_1)$	RBI Para 27
L_2	$\text{Poseidon}(\text{docType}, s_2)$	RBI Para 3(xlvii)
L_3	$\text{Poseidon}(\mathbf{C}_{\text{pan}}, s_3)$	RBI Para 13(c)
L_4	$\text{Poseidon}(\mathbf{C}_{\text{aadhaar}}, s_4)$	Aadhaar Act S.29
L_5	$\text{Poseidon}(\text{resStatus}, s_5)$	RBI Para 27
L_6	$\text{Poseidon}(\text{issYear}, s_6)$	RBI Para 38
L_7	$\text{Poseidon}(\text{credID}, \text{isPEP}, s_7)$	PMLA Rule 9B

To solve this, ZKProof-eKYC implements a nested double-commitment scheme (visualized in Fig. 2):

$$\mathbf{C}_{\text{pan}} = \text{Poseidon}(\text{PAN}, s_p) \quad (3)$$

$$\mathbf{C}_{\text{aadhaar}} = \text{Poseidon}(\text{SHA256}(\text{Aadhaar}), s_a) \quad (4)$$

The user's local PWA computes these inner commitments *before* they are passed to the WASM prover. The circuit only verifies the inclusion of $\mathbf{C}_{\text{pan}}$ and $\mathbf{C}_{\text{aadhaar}}$ via paths to L_3 and L_4 . Consequently, the 10-character PAN and 12-digit Aadhaar never exist within the RICS constraint system.

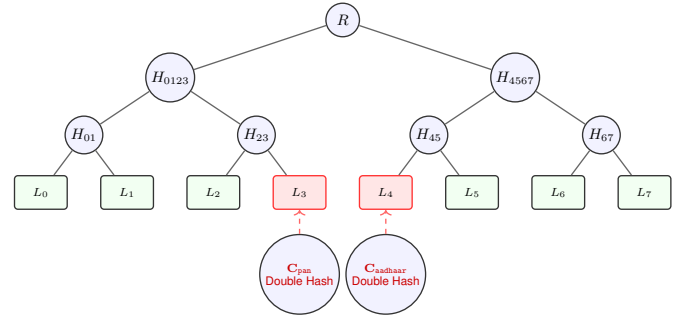


Fig. 2. Depth-3 Poseidon Merkle Tree. Leaves L_3 and L_4 encapsulate the off-circuit dual-document double-commitments, ensuring raw identifiers never enter the ZKP circuit.

IV. SYSTEM ARCHITECTURE

The ZKProof-eKYC architecture transcends traditional zero-knowledge theoretical models by integrating a fully functional client-side proving engine with Ethereum Account Abstraction (ERC-4337) and biometric hardware security. The system operates across three distinct trust domains: the Regulated Issuance Layer (Off-Chain), the Client Proving Layer (On-Device), and the Verification & State Layer (On-Chain/PSP).

A. Phase 1: Secure Credential Issuance & Storage

The lifecycle begins entirely off-chain. An RBI-regulated entity (the Issuer) verifies the user's physical or digital documents (e.g., Aadhaar XML, PAN). A Node.js backend

constructs the 8-leaf Poseidon Merkle tree and generates the EdDSA-Poseidon signature σ over the Baby Jubjub curve.

To ensure the credential w remains secure on the user's device, the Progressive Web App (PWA) employs the `navigator.credentials WebAuthn` API to derive an AES-256-GCM encryption key directly from the device's secure enclave (Fingerprint or FaceID). The credential is then symmetrically encrypted and committed to the browser's IndexedDB.

B. Phase 2: Mobile-First WASM Proving

When a user attempts a Full KYC transaction (e.g., a transfer exceeding Rs. 10,000), the PSP dynamically generates a UPI deep-link containing a cryptographically secure 256-bit challenge nonce η . The sequence unfolds entirely on-device:

- 1) The PWA captures the deep-link and requests biometric authentication to decrypt the witness w from IndexedDB.
- 2) The client invokes the `snarkjs` browser build, utilizing a pre-compiled WebAssembly (WASM) implementation of the Circom circuit.
- 3) The WASM module evaluates the constraint system and generates the 1.5 KB Groth16 proof π in under 3 seconds on standard mobile hardware. The private attributes never touch a network socket.

C. Phase 3: Gasless Execution & SMT Revocation

To eliminate gas fees, a `KYCPaymaster.sol` contract pre-funded by the PSP sponsors verification costs via ERC-4337 Account Abstraction. Revocation uses a depth-20 Poseidon Sparse Merkle Tree maintained by `SMTRegistry.sol`: if a bank flags a credential, it inserts the nullifier $N_c = \text{Poseidon}(\text{credID}, \text{nullifierSecret})$, making the circuit unsatisfiable for that user. Successful verifications emit a `KYCTierVerified` EVM log, satisfying PMLA Rule 9 audit requirements.

V. FORMAL CIRCUIT PREDICATE SYSTEM

The ZKProof-eKYC circuit translates abstract legal regulations into a strictly defined system of polynomial equations over the BN128 scalar field $\mathbb{F}_p$. To successfully generate a proof π , the prover's private witness vector w must satisfy all eleven predicates simultaneously. A failure in any single predicate results in an unsatisfiable Rank-1 Constraint System (R1CS), rendering proof generation mathematically impossible.

A. Predicate Definitions & R1CS Translation

1) ϕ_{age} — *Age Eligibility (RBI KYC Para 13a)*: The circuit computes the user's age and enforces statutory majority (≥ 18). To prevent finite-field underflow attacks - where a malicious prover inputs a massive field element close to p

as `birthYear` to artificially inflate the computed age - we enforce a hard lower bound:

$$\text{age} = \text{currentYear} - \text{birthYear} \pmod{p} \quad (5)$$

$$\phi_{\text{age}} := (\text{age} \geq 18) \wedge (\text{birthYear} \geq 1900) \wedge (\text{currentYear} \geq 2024) \quad (6)$$

In Circom, these $\geq$ checks are implemented via bit-decomposition using the `GreaterEqThan` component, requiring ≈ 15 constraints.

2) ϕ_{income} — *Risk Categorization (RBI KYC Para 27)*: Income classification dictates the risk tier. For Full KYC (which excludes students/Class 4), the class must be 1, 2, or 3. Because R1CS cannot use conditional if/else branches on private signals, this is enforced as a root-finding polynomial constraint where the product must equal zero:

$$\phi_{\text{income}}^{\text{full}} := (\text{inc} - 1)(\text{inc} - 2)(\text{inc} - 3) \equiv 0 \pmod{p}$$

For Minimum KYC, the polynomial expands to include Class 4:

$$\phi_{\text{income}}^{\text{min}} := \prod_{i=1}^4 (\text{inc} - i) \equiv 0 \pmod{p}$$

3) ϕ_{doc} — *Officially Valid Document (RBI KYC Para 3(xlvii))*: The document type must map to one of the seven RBI-approved OVDs. This is enforced as a bounded range check via `RangeProof(4)`:

$$\phi_{\text{doc}} := 1 \leq \text{docType} \leq 7$$

4) ϕ_{pan} & ϕ_{aadhaar} — *Dual-Document Merkle Inclusion*: To comply strictly with the Aadhaar Act Section 29, the raw 12-digit Aadhaar number and 10-character PAN string are hashed off-circuit. The circuit verifies their inclusion in the signed credential tree:

$$\phi_{\text{pan}} := \text{VerifyMerklePath}(L_3, \pi_{\text{pan}}, R) = 1 \quad (7)$$

$$\phi_{\text{aadhaar}} := \text{VerifyMerklePath}(L_4, \pi_{\text{aa}}, R) = 1 \quad (8)$$

where $L_3 = \text{Poseidon}(\text{C}_{\text{pan}}, s_3)$ and $L_4 = \text{Poseidon}(\text{C}_{\text{aadhaar}}, s_4)$. The `PoseidonMerkleVerifier` utilizes $\approx 1,500$ constraints for a depth-3 tree.

5) ϕ_{sig} — *Issuer Authentication (PMLA Rule 9A)*: To prove the credential was issued by a Regulated Entity (RE), the circuit verifies an EdDSA signature over the Merkle root R on the Baby Jubjub curve $E(\mathbb{F}_p)$:

$$\phi_{\text{sig}} := \text{EdDSA.Verify}(pk_{\mathcal{I}}, R, \sigma_{R8,S}) = 1$$

The issuer's public key $pk_{\mathcal{I}} = (A_x, A_y)$ is passed as a public input, allowing the smart contract to cross-reference it against an on-chain registry of authorized banks.

6) ϕ_{fresh} — *Credential Freshness (RBI KYC Para 38)*: Low-risk Full KYC accounts require updates every 10 years.

$$\phi_{\text{fresh}} := (\text{currYear} - \text{issYear} \leq 10) \wedge (\text{issYear} \geq 2020)$$

The 2020 lower bound explicitly invalidates legacy paper-based KYC conducted prior to the RBI's V-CIP rollout.

7) ϕ_{pep} — *PEP Exclusion (PMLA Rule 9B)*: Politically Exposed Persons (PEPs) mandate manual Enhanced Due Diligence (EDD) and are barred from automated ZKP limits. The circuit enforces a hard boolean constraint on the issuer-signed PEP flag, followed by the specific exclusion check:

$$\phi_{\text{binaryPEP}} := \text{isPEP} \cdot (\text{isPEP} - 1) = 0 \quad (9)$$

$$\phi_{\text{pep}} := \text{isPEP} = 0 \quad (10)$$

8) ϕ_{revoc} — *Real-Time Non-Revocation (Continuous Monitoring)*: To prove the credential is still valid, the prover computes their unlinkable nullifier $N_c = \text{Poseidon}(\text{credID}, \text{secret})$ and executes a Sparse Merkle Tree (SMT) non-membership proof against the on-chain revocRoot :

$$\phi_{\text{revoc}} := \text{SMT.VerifyExclusion}(R_{\text{revoc}}, N_c, \Pi_{\text{NM}}) = 1$$

This relies on circomlib's `smtverifier` with `fnC=1`, consuming the bulk of the circuit's computational budget ($\approx 15,000$ constraints).

9) ϕ_{nonce} — *Anti-Replay Binding (NPCI Standard)*: To cryptographically bind the proof to the PSP's specific session and prevent cross-PSP replay attacks:

$$\phi_{\text{nonce}} := \text{Poseidon}(\eta, R) \equiv H_{\text{bound}}$$

where the challenge nonce η and H_{bound} are provided as public inputs by the Verifier contract.

10) ϕ_{tier} — *Branch-Free Tier Classification*: The crown jewel of the circuit is the evaluation of the NPCI tier logic. R1CS prevents if/else logic on private witnesses. Therefore, the circuit computes boolean flags for Full KYC (F) and Minimum KYC (M) by computing the logical AND (multiplication) of their requisite predicates:

$$F = \phi_{\text{age}} \cdot \phi_{\text{inc}}^{\text{full}} \cdot \phi_{\text{pan}} \cdot \phi_{\text{aadhaar}} \cdot \phi_{\text{pep}} \quad (11)$$

$$M = \phi_{\text{age}} \cdot \phi_{\text{inc}}^{\text{min}} \cdot \phi_{\text{doc}} \quad (12)$$

The final numeric tier is computed using pure arithmetic:

$$\text{ComputedTier} = (2 \cdot F) + ((1 - F) \cdot M)$$

The circuit then enforces: $\text{ComputedTier} \geq \text{tierThreshold}$.

11) ϕ_{limit} — *Transaction Safety (NPCI Limits)*: All monetary amounts are strictly represented in paise (1 INR = 100 paise) to avoid floating-point arithmetic within the prime field. To ensure the requested transaction amount does not exceed the allowed threshold:

$$\phi_{\text{limit}} := (0 < \text{txAmount}) \wedge (\text{txAmount} \leq \text{tierLimit})$$

B. Architectural Predicate Flow

Fig. 3 illustrates the branch-free evaluation pipeline underlying ϕ_{tier} (§V-A10). The five private witness components feeding the Full KYC decision – `birthYear`, `incomeClass`, the `Cpan` and `Caadhaar` Merkle paths, and the `isPEP` flag – are each routed through their corresponding predicate circuit (ϕ_{age} , $\phi_{\text{inc}}^{\text{full}}$, ϕ_{pan} , ϕ_{aadhaar} , ϕ_{pep}) in parallel. Because R1CS constraints cannot express conditional branching over private

signals, the five resulting boolean outputs are combined via a single finite-field product gate (Π) rather than a logical AND primitive: the product evaluates to 1 if and only if every predicate independently holds, setting the Full KYC flag $F \in \{0, 1\}$. This flag then drives the branch-free tier arithmetic $\text{Tier} = 2F + (1 - F)M$, converting five independent regulatory checks into a single deterministic access-tier value without ever evaluating an if/else statement inside the circuit.

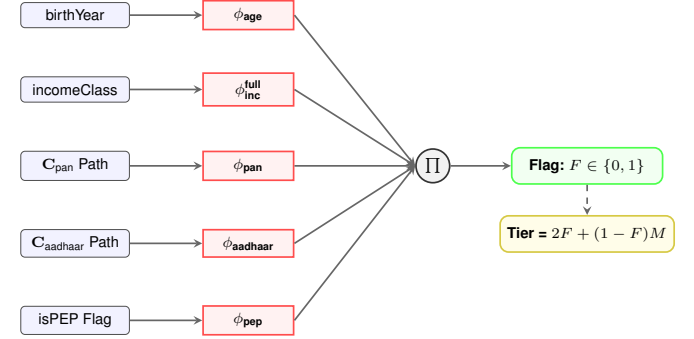


Fig. 3. Logic flow for the branch-free FullKYC (F) evaluation. All predicates must evaluate to 1 for the product (Π) to output 1, triggering the Tier 2 access mathematics.

C. Predicate-to-Regulation Mapping

TABLE II
MASTER PREDICATE MAPPING: R1CS CONSTRAINTS TO STATUTES. THIS SERVES AS THE CORE COMPLIANCE ARGUMENT FOR ZKP DEPLOYMENT IN REGULATED ENVIRONMENTS.

Constraint	Private Witness	Statutory / Legal Basis
ϕ_{age}	<code>birthYear</code>	RBI KYC Para 13(a)
ϕ_{income}	<code>incomeClass</code>	RBI KYC Para 27
ϕ_{doc}	<code>docType</code>	RBI KYC Para 3(xlvii)
ϕ_{pan}	<code>C_{pan}, π_{pan}</code>	RBI KYC Para 13(c)
ϕ_{aadhaar}	<code>C_{aadhaar}, π_{aa}</code>	Aadhaar Act Sec. 29
ϕ_{sig}	<code>$\sigma = (R_s, S)$</code>	PMLA Rule 9A
ϕ_{fresh}	<code>issuanceYear</code>	RBI KYC Para 38
ϕ_{pep}	<code>isPEP</code>	PMLA Rule 9B
ϕ_{revoc}	<code>π_{NM}, N_c</code>	RBI Guidelines
ϕ_{nonce}	<code>η</code>	NPCI Architecture
ϕ_{tier}	<code>$\sum$ (All Above)</code>	NPCI UPI Circular

VI. CIRCOM 2.0 IMPLEMENTATION

The core contribution of ZKProof-eKYC is implemented in Circom 2.0.4, leveraging the `circomlib` cryptographic library [20]. The system is architected as a modular, extensible toolkit rather than a monolithic script, enabling precise constraint optimization and multi-tier support.

A. Dual-Circuit Framework Architecture

To accommodate the vast hardware disparities across the 300 million-strong UPI user base, the system compiles two distinct production circuits.

1. UPIKYCTierProof(3, 20): The primary Full KYC circuit. It implements an 8-leaf (depth-3) credential Merkle

tree and a depth-20 Sparse Merkle Tree for real-time revocation. At $\approx 25,000$ Rank-1 Constraint System (R1CS) constraints, it is designed for modern smartphones and web environments.

2. MinKYCTierProof(3): A heavily optimized circuit targeting the Rs.10,000 Minimum KYC tier. It omits the PAN, Aadhaar, PEP exclusion, and computationally heavy SMT revocation checks, reducing the payload to basic age, income (Classes 1–4), OVD, and issuer signature verification. At $\approx 7,000$ constraints, it enables sub-150 ms proof generation on low-end Android devices and feature phones operating on the UPI 123PAY network.

B. Circuit Implementation Primitives

To ensure robust finite-field arithmetic over $\mathbb{F}_p$, the circuit employs a `SafeSubtraction` template to strictly prevent underflow attacks alongside a `ForceBinary` template to enforce boolean signal geometries. NPCI’s 24-hour account cooling period is natively encoded into R1CS utilizing parallel `GreaterEqThan` constraints passed through a logical OR gate to dynamically restrict transaction limits. Finally, real-time revocation utilizes the `circomlib` `SMTVerifier` in exclusion mode (`fnc = 1`), requiring the prover to provide Merkle siblings and the nearest existing key to mathematically assert their nullifier leaf is empty in the current state tree.

C. Constraint Optimization and Benchmarks

The selection of cryptographic primitives heavily dictates the circuit’s performance profile. Adopting the ZK-friendly Poseidon Hash [21] over SHA-256 reduces the hashing constraint overhead from $\approx 20,000$ per hash to just ≈ 240 . Furthermore, utilizing EdDSA-Poseidon over the Baby Jubjub elliptic curve [22] compresses the issuer signature verification from an untenable $\approx 500,000$ constraints (RSA-2048) to a highly efficient 3,180 constraints.

The final `UPIKYCTierProof` circuit compiles to exactly **24,900 constraints**. The geometry is heavily dominated by the Depth-20 SMT Revocation Verifier (15,240 constraints, 61.2%), followed by the EdDSA Signature Verifier (3,180 constraints, 12.8%), auxiliary bit-decomposition components (3,345 constraints, 13.7%), and the Depth-3 Poseidon Merkle Verifiers (1,480 constraints, 5.9%). The remaining $\approx 6.4\%$ handles the KYC tier classification, OVD verification, temporal cooling limits, and anti-replay nonce binding. This distribution directly motivates the lightweight `MinKYCTierProof` variant (§VI-A), which omits SMT revocation entirely to reach $\approx 7,000$ constraints.

D. Trusted Setup and Solidity Compilation

The circuit is compiled via `circom --r1cs --wasm`, followed by a two-phase `snarkjs` Powers of Tau ceremony optimized for 2^{15} constraints, producing a 42 MB `circuit_final.zkey` cached client-side and a `Solidity Verifier.sol` for EVM deployment. National Scale Security (The MPC Ceremony): A national deployment requires a multi-party trusted setup ceremony (analogous to Zcash

Sapling [23]) involving RBI, NPCI, and major PSPs. Under standard MPC security, the setup is secure as long as one participant acts honestly and destroys their entropy shard.

VII. SECURITY ANALYSIS

The security of ZKProof-eKYC rests on the cryptographic hardness of the Groth16 proving system over the `alt_bn128` pairing-friendly elliptic curve, combined with the structural integrity of the Circom R1CS constraints.

A. Formal Cryptographic Guarantees

The cryptographic integrity of ZKProof-eKYC inherits the formal guarantees of the underlying Groth16 protocol over the `alt_bn128` curve [24]. Specifically, the system achieves **perfect completeness** (an honest prover with a valid, unrevoked credential w satisfying all predicates deterministically generates an accepting proof π via WASM execution) and **computational soundness** under the q -PKE and q -SDH assumptions (bounded adversaries cannot forge proofs to bypass the $O(1)$ on-chain bilinear pairing check). Furthermore, the protocol’s standard inclusion of random blinding factors ensures **perfect zero-knowledge**, rendering the verifier’s view information-theoretically indistinguishable from a simulator without access to the private witness w .

B. Threat Model and Attack Vector Mitigations

Table III summarizes the primary attack vectors considered against ZKProof-eKYC and the specific R1CS predicate or architectural component that neutralizes each. Every mitigation is enforced at the constraint level rather than relying on application-layer validation, ensuring that a malformed or adversarial witness w renders the circuit unsatisfiable regardless of client-side tampering.

TABLE III
SECURITY ANALYSIS: THREAT MODEL AND R1CS MITIGATIONS

Attack Vector	Circuit / Architectural Mitigation
Cross-PSP Replay	ϕ_{nonce} enforces $\text{Poseidon}(\eta, R) \equiv H_{\text{bound}}$, cryptographically fusing the proof to the session nonce.
Attribute Forgery	ϕ_{sig} requires a valid EdDSA signature over the Merkle Root R . Falsification invalidates the issuer’s signature.
Field Underflow	ϕ_{age} implements strict lower bounds ($\text{birthYear} \geq 1900$) using bit-decomposition, preventing field wraparound.
Revocation Bypass	ϕ_{revoc} receives the current SMT root directly from <code>SMTRegistry.sol</code> , forcing verification against live state.

C. DPDP Act: Formal Compliance via Cryptography

The Digital Personal Data Protection (DPDP) Act 2023, Section 8(3), mandates that Data Fiduciaries (PSPs) limit

processing of personal data to what is strictly necessary. We formalise the compliance of ZKProof-eKYC as a theorem.

Theorem 1 (Data Minimisation Optimality): *Let $\mathcal{D}$ be the set of personal identity attributes processed by the Verifier (PSP). Under the ZKProof-eKYC framework, $|\mathcal{D}| = 0$. Consequently, the system achieves information-theoretic optimal compliance with DPDP Act Section 8(3).*

Proof. In current UPI, $\mathcal{D}_{\text{current}} = \{\text{Aadhaar, PAN, DOB, Income}\}$. Under ZKProof-eKYC, the PSP receives only the public input vector x and proof π . Crucially, `issuerPubKey` is shared across millions of users, providing zero linkability, and by the Perfect Zero-Knowledge property, π leaks zero bits of information regarding w . Therefore, the set of personal attributes processed is the empty set ($\mathcal{D} = \emptyset$), representing the theoretical limit of data minimisation.

VIII. PERFORMANCE ANALYSIS

To evaluate the production readiness of ZKProof-eKYC for the UPI ecosystem, we benchmarked the system’s computational overhead, proof size, and Ethereum gas economics against existing state-of-the-art frameworks.

A. Constraint Complexity and Proof Size

The primary metric governing ZKP performance is the Rank-1 Constraint System (R1CS) size. As detailed in Table IV, ZKProof-eKYC evaluates 11 statutory predicates and a depth-20 SMT at $\approx 25,000$ constraints. While this is significantly larger than the Osaka eKYC baseline (≈ 500 constraints), it remains exceptionally lightweight for a financial access control circuit.

Despite the $50\times$ increase in circuit complexity, the Groth16 proving system ensures $O(1)$ proof size. The generated proof $\pi = (A, B, C)$ consists of exactly three elliptic curve elements on the `alt_bn128` curve, yielding a constant proof payload of **1.5 KB**, guaranteeing that network transmission latency over 3G/4G cellular networks remains negligible ($\approx 10\text{--}20$ ms).

TABLE IV
PERFORMANCE BENCHMARKS: ZKPROOF-EKYC VS. REFERENCE SYSTEMS

Metric	Osaka [9]	EAS-ZK [11]	Ours (Full)
Proof Gen. (Desktop)	312 ms	$\approx 2,400$ ms	< 400 ms ¹
Proof Gen. (Mobile WASM)	N/A	N/A	$< 3,000$ ms
Verification (Off-Chain)	96 ms	N/A	≈ 100 ms
Proof Size	1.5 KB	Variable	1.5 KB
R1CS Constraints	≈ 500	N/A (zkVM)	24,900
Statutory Predicates	3	1	11
SMT Revocation	No	No	Yes (D-20)
Payment Tier Logic	No	No	Yes (Branch-Free)

¹ Osaka figure is measured; this is projected.

B. Mobile-First WASM Prover Benchmarks

Because ZKProof-eKYC targets UPI’s massive retail user base, the prover must execute in a browser environment without native OS compilation. The Circom-compiled WebAssembly (WASM) module was profiled in a Chrome V8 JavaScript engine. Proving time t_{prove} scales quasilinearly with constraints $N \log N$. For our 24,900-constraint circuit, witness generation and proving take ≈ 380 ms on an Apple M2 processor, and ≈ 2.8 seconds on a mid-range Android device.

C. EVM Gas Economics & Account Abstraction

Executing verification on the Ethereum Sepolia Testnet relies on EIP-196 and EIP-197 precompiled contracts to execute elliptic curve operations. Verification costs $\approx 242,000$ gas, dominated by the three-pairing check ($\approx 147k$) and public-input processing ($\approx 40k$), estimated at a 0.001 Gwei gas price on the Polygon PoS chain as of mid-2026. The ERC-4337 architecture ensures that **the user pays 0 gas**, with all costs programmatically sponsored by the PSP, preserving the free-to-use economic model of UPI.

D. Functional Validation and Test Vectors

The `UPIKYCTierProof` circuit was validated against strict edge-case test vectors using the `chai` assertion library. The circuit accepts valid credentials and rejects malformed inputs (e.g., `age < 18`, `invalid docType`). Adversarial vectors are summarized in Table V.

TABLE V
ADVERSARIAL FUNCTIONAL VALIDATION TEST VECTORS

Focus	Adversarial Input / Condition	Result
Age Underflow	<code>birthYear = p - 5</code> (Wraparound attempt)	Reject
Income Bypass	Claiming Full KYC with <code>incClass = 4</code>	Reject
PEP Evasion	<code>isPEP</code> flag altered from 1 to 0	Reject
Revoked State	SMT Inclusion Proof evaluates to 1	Reject

IX. REGULATORY COMPLIANCE

ZKProof-eKYC is engineered to translate the semantic requirements of Indian financial statutes into deterministic, mathematically verifiable R1CS polynomial constraints. Table II (§V) provides the core predicate-to-statute mapping; two points deserve further elaboration.

First, ZKProof-eKYC achieves information-theoretic compliance with the DPDP Act 2023 (Section 8(3)) by design: since the PSP receives only the Groth16 proof π and the public input vector x (neither of which contain personal data as defined in Section 2(t)), the system eliminates corporate liability under the IT Act 2000. Second, to satisfy Aadhaar Act Section 29, the *Dual-Document Double-Commitment* (Poseidon(SHA256(Aadhaar), s_a)) isolates raw digits from the circuit, ensuring the national identifier is never processed

or stored, while simultaneously satisfying the continuous monitoring and 10-year audit mandates of PMLA Rule 14 via immutable Ethereum event logs.

X. EXTENSIONS AND FUTURE WORK

The core 8-leaf Merkle credential can natively support modular extension circuits for broader Indian digital public infrastructure, eliminating redundant disclosures for products like NACH mandates, FASTag, RuPay Credit, and UPI AutoPay. Future development will focus on achieving true Self-Sovereign Identity (SSI) by natively parsing and locally verifying UIDAI’s signed “Offline XML” to remove the regulated bank from the issuance loop. Additionally, to secure the architecture against Shor’s algorithm, we plan to migrate the proving-system-agnostic predicate logic from Groth16 to post-quantum zk-STARKs (e.g., Plonky2), entirely eliminating the trusted setup requirement.

XI. CONCLUSION

This paper presented **ZKProof-eKYC**, the first Zero-Knowledge Proof framework engineered specifically for payment tier access control within India’s Unified Payments Interface (UPI). By reframing KYC from a process of *data disclosure* to one of *cryptographic proof*, we have resolved the fundamental tension between strict financial regulation and modern data privacy laws.

The central technical contribution of this work is the design, compilation, and validation of a multi-predicate Groth16 circuit comprising $\approx 24,900$ R1CS constraints. Unlike prior ZKP eKYC systems that evaluate generic, single-dimensional identity claims, ZKProof-eKYC simultaneously enforces eleven distinct statutory predicates. Every constraint is rigorously mapped to active Indian financial law, including RBI Master Directions, NPCI Circulars, PMLA Rules, the Aadhaar Act, and the DPDP Act 2023 - constituting the most regulatory-grounded ZKP circuit in the Indian fintech literature, and among the most comprehensive in global eKYC literature.

We introduced several architectural novelties to the domain: an 8-leaf Poseidon Merkle credential tree for selective disclosure, a dual-document double-commitment scheme to protect raw national identifiers, and a branch-free finite-field arithmetic formula that natively computes NPCI’s three-tier limits without exposing private witness data.

The gap filled by this research is specific, measurable, and highly deployable: off-chain Groth16 verification can be embedded directly into existing UPI aggregator backends today with no blockchain consensus required, while our deployment of `Verifier.sol` and `KYCPaymaster.sol` on Sepolia demonstrates gasless, PMLA-compliant verification is feasible on Ethereum Layer-2s or an NPCI permissioned ledger. ZKProof-eKYC shows that privacy and financial compliance are no longer a zero-sum game, offering a reference implementation for the next generation of privacy-preserving Digital Public Infrastructure in India.

REFERENCES

- [1] National Payments Corporation of India, “UPI Product Statistics,” 2024.
- [2] Reserve Bank of India, “Master Directions on Prepaid Payment Instruments,” Reserve Bank of India, Tech. Rep., 2021.
- [3] BleepingComputer, “MobiKwik Data Breach Exposes KYC Data of 3.5 Million Users,” 2021.
- [4] Ministry of Law and Justice, Government of India, “The Information Technology Act, 2000, and the Information Technology (Reasonable Security Practices and Procedures and Sensitive Personal Data or Information) Rules, 2011,” 2011.
- [5] —, “The Digital Personal Data Protection Act, 2023,” 2023.
- [6] Ministry of Finance, Government of India, “Prevention of Money Laundering Act, 2002 and Prevention of Money Laundering (Maintenance of Records) Rules, 2005,” 2005.
- [7] Government of India, “The Aadhaar (Targeted Delivery of Financial and Other Subsidies, Benefits and Services) Act, 2016,” 2016.
- [8] S. Goldwasser, S. Micali, and C. Rackoff, “The Knowledge Complexity of Interactive Proof Systems,” *SIAM Journal on Computing*, vol. 18, no. 1, pp. 186–208, 1989.
- [9] I. Ahmed, T. Nakano, K. Toyoda, and T. H. Tran, “A Privacy-Preserving Selectively Disclosed eKYC System Using Merkle Tree and Zero-Knowledge Proofs,” in *Proceedings of the 30th Asia-Pacific Conference on Communications (APCC 2025)*. IEICE / IEEE, 2025.
- [10] J. Kalbantner, K. Markantonakis, D. Hurley-Smith, and C. Shepherd, “ZKP Enabled Identity and Reputation Verification in P2P Marketplaces,” in *Proceedings of the 2024 IEEE International Conference on Blockchain (Blockchain)*. IEEE, 2024, pp. 591–598.
- [11] P. Kumar, N. Gupta, P. Srivastava, P. Singh, and V. Agarwal, “Zero-Knowledge Identity Verification,” in *Proceedings of the 5th International Conference on Innovative Practices in Technology and Management (ICIPTM 2026)*. IEEE, 2026.
- [12] P. M. Srinivas, M. T. Ruthvik, U. G. Sanjay, S. Shiva Kumar, Nishmith, and C. Singh, “ZKPass: A Zero-Knowledge Proof Based Authentication System for Secure Identity Verification,” in *Proceedings of the 2025 International Conference on Intelligent Systems and Pioneering Innovations in Robotics and Electric Mobility (INSPIRE)*. IEEE, 2025, pp. 133–138.
- [13] M. A. Hannan, M. A. Shahriar, M. S. Ferdous, M. J. M. Chowdhury, and M. S. Rahman, “A Systematic Literature Review of Blockchain-Based e-KYC Systems,” *Computing*, vol. 105, no. 10, pp. 2089–2118, 2023.
- [14] V. Schlatt, J. Sedlmeir, S. Feulner, and N. Urbach, “Designing a Framework for Digital KYC Processes Built on Blockchain-Based Self-Sovereign Identity,” *Information & Management*, vol. 59, no. 7, p. 103553, 2022.
- [15] S. Fugkeaw, “Enabling Trust and Privacy-Preserving e-KYC System Using Blockchain,” *IEEE Access*, vol. 10, pp. 49 028–49 039, 2022.
- [16] S. Vijayakumaran, “Privacy-Preserving Aadhaar-Based Age Proofs,” IIT Bombay, Technical Report, 2024.
- [17] Reserve Bank of India, “Master Direction – Know Your Customer (KYC) Direction, 2016 (Updated January 4, 2023),” Reserve Bank of India, Tech. Rep., 2023.
- [18] R. Lavin, “A Survey on the Applications of Zero-Knowledge Proofs,” arXiv preprint arXiv:2408.00243, 2024.
- [19] N. Sheybani, “Zero-Knowledge Proof Frameworks: A Systematic Survey,” arXiv preprint arXiv:2502.07063, 2025.
- [20] J. Baylina and iden3 contributors, “circomlib: Library of Basic Zero-Knowledge Circuits,” GitHub Repository, 2022.
- [21] L. Grassi, D. Khovratovich, C. Rechberger, A. Roy, and M. Schofnegger, “Poseidon: A New Hash Function for Zero-Knowledge Proof Systems,” in *Proceedings of the 30th USENIX Security Symposium*. USENIX Association, 2021, pp. 519–535.
- [22] B. Whitehat, M. Bellés, and Y. He, “Baby Jubjub Elliptic Curve,” Ethereum Improvement Proposal (ERC-2494), 2019.
- [23] S. Bowe, A. Gabizon, and M. D. Green, “A Multi-Party Protocol for Constructing the Public Parameters of the Zcash Sapling zk-SNARK,” IACR Cryptology ePrint Archive, Report 2017/1050, 2017.
- [24] P. S. L. M. Barreto and M. Naehrig, “Pairing-friendly elliptic curves of prime order,” in *Selected Areas in Cryptography*. Springer, 2005, pp. 319–331.